

Security Event Information Management

Industry Research Project





(COMP 5800)
Industry Research Project

Course Coordinator: Masud Karim

Project Report:

Security Event Information Management

Group: C261W-5304

	Name	ID
Student 1	Aakritansh Modgil	A3182984
Student 2	Jithu Johan Jose	A1985627
Student 3	Promise Rijal	A1980984
Student 4	Humayra Ashrafi	A3037578
Student 5	Ruichao Li	A1942645
Student 6	Junaid Abrar Razeen	A1991907

Client/Sponsor	Eagle
Mentor	David Menzies

DATE: 20-05-2026

Table of Contents

Table of Contents	3
1. Executive Summary	5
2. Project Background	6
3. Scope and Deliverables.....	6
3.1. Scope:	6
3.2. Out of Scope:	6
3.3. Key Assets:	7
4. Business Problem and Opportunity	7
5. SIEM Deployment Options for Bedminster Health	8
6. SIEM Market Review	9
6.1. Evaluation Methodology.....	9
6.2. Why Microsoft Sentinel was Selected?.....	10
7. Proposed Solution Architecture	11
7.1. Log Ingestion Assumption and Data Architecture.....	12
7.2. Log Normalisation Strategy.....	13
7.3. Legacy Device and Log Onboarding Model.....	14
8. Detection and Response Engineering	15
8.1. KQL Detection Engineering for Bedminster Health	15
8.2. Reducing MTTD, MTTR, MTTF, and MTBF.....	15
8.3. Reducing False Positives and Improving Workflow	16
9. Detection and Response Engineering	16
9.1. Prioritisation of Connectors.....	16
10. Data Management and Retention.....	17
10.1. Data Retention and Data Lake Strategy.....	17
10.2. Log Integrity and Non-Repudiation	17
11. Operation Resilience	18
11.1. Handling Spikes, Failures, and Crashes During Migration.....	18
11.2. Break-Glass Access and Emergency Cloud Operations.....	18
12. Compliance and Governance	18
12.1. Compliance, Accountability, and Shared Responsibility	18
12.2. SIEM Transition Risk Register	19
13. Organisational Benefits.....	20
13.1. Improved Visibility and Governance.....	20
13.2. Faster, More Coordinated Incident Response.....	20

14.	Implementation Roadmap	21
15.	Future Work and Extension Opportunities.....	21
16.	Reflection on Team and Individual Contribution.....	21
17.	Conclusion	22
18.	Approval.....	23
	References	24

1. Executive Summary

With one large hospital, four satellite hospitals, multiple outpatient clinics, and over 6,000 employees spread across about 150 servers and 2,000 workstations, **Bedminster Health** runs a sizable multi-site healthcare facility. The organisation lacks centralised real-time security monitoring, which means that suspicious activity is often discovered only after an incident has occurred, despite producing significant security telemetry across firewalls, routers, and servers. This report presents a justified business case for deploying Microsoft Sentinel as Bedminster Health's SIEM platform.

Following a structured evaluation of five platforms, Palo Alto Cortex XSIAM, Microsoft Sentinel, Splunk Enterprise Security, IBM QRadar, and LogRhythm, Sentinel was selected on the basis of technical suitability, integrated automation, cloud scalability, and operational fit with Bedminster Health's staffing and infrastructure constraints. The proposed architecture assumes 100 GB of daily log ingestion, combining Microsoft Sentinel with Entra ID P2, Azure Arc, a collector virtual machine, and Azure storage services, at an estimated cost of A\$20,318.87 per month. This investment is justified through measurable organisational benefits: reduced MTTD and MTTR, improved audit readiness, lower false-positive burden, and reduced exposure to healthcare breach costs that routinely reach millions of dollars per incident (Australian Clinical Labs, 2025).

2. Project Background

Bedminster Health operates in a heavily regulated environment where service availability, patient confidentiality, and rapid cyber incident response are critical. Because logs are not centrally monitored in real time, malicious activity may remain undetected until significant harm has occurred.

Delayed detection creates risks beyond data loss, a ransomware event or clinical system compromise may disrupt patient care, create legal liability, and produce direct financial losses through response and recovery costs. The purpose of this project is to produce a defensible business case recommending a suitable SIEM platform, a practical onboarding strategy, a high-level operating model, and an implementation roadmap for Bedminster Health.

3. Scope and Deliverables

This project is limited to designing and justifying a SIEM solution for Bedminster Health, rather than deploying one in production.

3.1. Scope:

The following outlines the boundaries of work undertaken for this project.

- Conduct research and evaluation of suitable SIEM solutions for Bedminster Health.
- Design a high-level SIEM architecture and log onboarding model for existing network, server, and workstation infrastructure.
- Identify security monitoring and visibility requirements aligned with Bedminster Health's risk profile and business needs.
- Review and compare candidate SIEM platforms against functional, technical and organisational criteria.
- Calculate the needs for data ingestion, storage, and retention, taking into account cost modelling for various licensing and deployment choices..
- Propose a staged rollout and implementation approach, from initial pilot through to broader adoption.
- Describe the governance, privacy, and regulatory issues that are pertinent to the organization's use of a SIEM platform.

3.2. Out of Scope:

The following activities fall outside the boundaries of this project.

- Live deployment or configuration of a SIEM platform in Bedminster Health's production environment.
- Ongoing monitoring, tuning, and operations (e.g., SOC runbooks, 24/7 coverage) after deployment.

- Commercial activities such as vendor contract negotiation or procurement processes.
- Detailed end user and SOC analyst training development or delivery.

3.3. Key Assets:

The following deliverables will be produced as part of this project.

- A thorough analysis of the advantages, disadvantages, and suitability of the shortlisted SIEM products for Bedminster Health.
- A justified recommendation of a preferred SIEM solution, supported by technical and business reasoning.
- A high-level SIEM architecture and log onboarding model for key log sources.
- A cost and data retention strategy covering licensing, storage, and growth over time.
- A compliance aware design position addressing relevant regulatory and organisational requirements.
- An implementation roadmap that Bedminster Health can use to proceed to a subsequent execution phase.

4. Business Problem and Opportunity

The issue is Bedminster Health is lacking in true real-time ability to detect, correlate and act on security events throughout its multi-site environment. Logs are spread out between systems and formats, which results in a lack of visibility and an increased operational, legal, and cybersecurity risk (ACSC 2024).

This is a chance to move from the reactive to proactive detection and response. A robust SIEM can help centralise event data, normalise complex log files, correlate events between users, hosts and systems, and enable automated playbooks for event triage to help analysts reduce effort, boost operational resiliency, regulatory readiness and executive visibility.

5. SIEM Deployment Options for Bedminster Health

Selecting the right SIEM deployment model directly affects compliance, operational complexity, and cost for Bedminster Health. With a 30-person IT team across five sites, the choice between on-premises, PaaS, and SaaS determines how much platform burden falls on internal staff versus the vendor.

Component	On-Premises	PaaS	SaaS
Platform ownership	Hospital owns and manages all hardware, OS, storage, and SIEM software.	Cloud provider manages infrastructure; hospital configures and manages SIEM components.	Provider delivers a complete SIEM service; hospital configures rules and integrations.
Compliance & data residency	Full control over data location; full responsibility for proving compliance.	Data location selectable; residency and retention must be correctly configured.	Regional options and built-in retention features; hospital ensures settings meet privacy regulations.
Data retention & backup	Hospital designs and operates all backups, archives, and multi-year log retention.	Retention built on cloud storage services; misconfiguration risk is higher.	Backup and long-term storage largely built-in; retention set via configuration.
Availability & DR	Hospital must build redundancy across sites; local outages can take SIEM offline.	HA and DR depend on how well cloud components are architected across regions.	Provider handles platform HA and DR; hospital focuses on collector buffering during outages.
Operational complexity	Highest: patching, scaling, upgrades, and capacity planning fall on the IT team.	Medium–high: less hardware but significant ongoing cloud stack maintenance.	Lower: vendor handles platform tasks; team focuses on rules, dashboards, and alerts.
Scalability	Requires new hardware purchases; slow and capital-intensive.	Easier to scale cloud resources but team must size and manage them.	Elastic by design; scales with data volume without hardware changes.
Cost model	Large upfront CapEx plus ongoing OpEx for power, cooling, and staff.	Mainly OpEx across multiple cloud services; cost complexity if poorly planned.	OpEx subscription or consumption model; predictable platform cost.
Satellite hospital impact	May require local appliances or complex routing to a central data centre.	Each site needs reliable internet/VPN; local caching must be designed by the team.	Each site uses a local collector forwarding to SaaS; platform resilience is built-in.

Table 1: SIEM Deployment Options for Bedminster Health.

Based on this comparison, the SaaS model is the most appropriate deployment option for Bedminster Health. Managing an on-premises SIEM across five hospital sites would introduce significant infrastructure overhead, requiring the IT team to maintain hardware, manage multi-site redundancy, and handle long-term log retention, all while responding to live security incidents. A PaaS approach reduces hardware burden but still demands considerable cloud architecture expertise. As a SaaS SIEM offered by Microsoft Azure, Microsoft Sentinel gives the vendor full control over detection rules, retention policies, and compliance settings while transferring platform responsibility to the vendor. Its implementation in Australian Azure regions guarantees that data residency requirements under Australian privacy law are fulfilled without the need for extra architectural complexity.

6. SIEM Market Review

The following table compares five leading SIEM platforms evaluated for Bedminster Health across pricing, monthly cost at 100 GB/day ingestion, and SOAR capability. Each platform was assessed for its suitability against Bedminster Health's operational scale, staffing constraints, and hybrid cloud direction.

Product	Unit Pricing Model (Approx.)	Example Monthly Cost (100 GB/day)	SOAR Capability/Product
Microsoft Sentinel	~6-7 AUD per GB ingested (usage based).	~19,000 AUD/month.	Built-in SOAR via Azure Logic Apps playbooks.
Splunk Enterprise Security	~6-7 AUD per GB ingested (often discounted).	~18,000-22,000 AUD/month.	Splunk SOAR (separate but integrated).
IBM QRadar	~5-10 AUD per EPS/month (bundle-dependent).	~10,000-20,000 AUD/month equivalent for a mid-size healthcare load.	IBM QRadar SOAR (formerly Resilient).
LogRhythm SIEM	~20-40 AUD per licensed user/month plus platform.	~8,000 - 15,000 AUD/month.	Built-in SOAR in NextGen SIEM.
Palo Alto Cortex XSIAM	7+ AUD per GB fully loaded.	20,000+ AUD/month.	Native SIEM+SOAR in XSIAM, extendable with Cortex XSOAR.

Table 2: SIEM Platform Pricing and SOAR Capability Comparison.

6.1. Evaluation Methodology

The business case compared five leading SIEM platforms on cost, capability, and organisational fit. All five deliver core SIEM functions but differ significantly in deployment complexity, usability, and alignment with Bedminster Health's size and hybrid cloud direction. Sentinel was chosen for its best overall balance: strong analytics, healthcare-appropriate cloud deployment, and a user experience a small, Microsoft-oriented team can realistically operate.

Platform	Strengths	Risks	Usability & Training
Microsoft Sentinel	Cloud-native SIEM+SOAR with strong Microsoft 365, Defender, and Azure integration.	Cost rises with high data volumes; non-Microsoft integrations require effort.	Familiar Azure portal; KQL aligned to existing Microsoft skills.
Splunk Enterprise Security	Very powerful search and analytics with a large app ecosystem.	High licence and infrastructure cost; often needs dedicated Splunk engineers.	Steep SPL learning curve; significant formal training required.
IBM QRadar	Mature correlation engine; strong for on-premises and regulated sectors.	Complex customisation; slower UI; heavier infrastructure footprint.	Assumes experienced QRadar admins; tuning takes specialist knowledge.
Palo Alto Cortex XSIAM	AI-driven platform unifying SIEM, XDR, SOAR, and attack surface management.	Best value only if already invested in Palo Alto; uses proprietary XQL.	Harder for small teams; requires ongoing agent management and training.
LogRhythm	Solid threat detection and compliance reporting for mid-to-large organisations.	Complex interface; customisation and scaling challenging for small teams.	Higher learning curve; agent management overhead noted in reviews.

Table 3: Comparison of SIEM Tools.

6.2. Why Microsoft Sentinel was Selected?

Microsoft Sentinel was selected for its combination of value for money, operational fit, cloud scalability, and integrated automation. Unlike competing products requiring separate SOAR platforms, Sentinel includes native automation through Logic Apps playbooks, eliminating on-premises infrastructure overhead. Deployment in Australian Azure regions supports data residency expectations under Australian privacy law (OAIC, 2023).

Sentinel suits Bedminster Health because the organisation requires enterprise-grade visibility but lacks the dedicated SOC team needed for a complex on-premises deployment. Its alignment with Entra ID and Defender reduces integration friction for an established Microsoft-oriented IT function (Microsoft, 2024b).

7. Proposed Solution Architecture

The recommended solution comprises Microsoft Sentinel, Entra ID P2, Azure Arc, a collector virtual machine, and Azure Storage services, totalling an estimated A\$20,318.87 per month (~A\$244,000 annualised).

Your Estimate

✓ Azure Migrate	?	There is no charge to use Azure Migrate.	+ -	Upfront: A\$0.00	Monthly: A\$0.00
✓ Azure Arc	?	Azure Arc enabled Servers: Azure Policy guest co...	+ -	Upfront: A\$0.00	Monthly: A\$8.71
✓ Microsoft Entra ID (formerly Azure AD)	?	Premium P1 - 0 users, Premium P2 - 30 users, Ent...	+ -	Upfront: A\$0.00	Monthly: A\$815.85
✓ Microsoft Sentinel	?	Logs ingested - 100 GB per day of Analytics tier a...	+ -	Upfront: A\$0.00	Monthly: A\$19,388.51
✓ Virtual Machines	?	1 D2 v3 (2 vCPUs, 8 GB RAM) x 730 Hours (Pay as ...	+ -	Upfront: A\$0.00	Monthly: A\$101.73
✓ Azure Storage Discovery	?	Azure Storage Discovery: 1 Storage Account Anal...	+ -	Upfront: A\$0.00	Monthly: A\$4.06

Support

SUPPORT:

Basic (Included)

[?](#)

A\$0.00

Select your program/offer

LICENSING PROGRAM:

Microsoft Customer Agreement (MCA)

[?](#)

[Log in](#) to see your Azure agreement pricing.

☒ Show Dev/Test Pricing [?](#)

Estimated upfront cost

A\$0.00

Estimated monthly cost

A\$20,318.87

Export

Save

Share

[Log in](#) to save and share cost estimates.

CURRENCY

Australia – Dollar (\$) AUD

1 USD = 1.45 AUD

Figure 1: Microsoft Sentinel Pricing.

The solution totals an estimated A\$20,318.87 per month (~A\$244,000 annualised), covering Sentinel, Entra ID P2, Azure Arc, a collector VM, and Azure Storage.

7.1. Log Ingestion Assumption and Data Architecture

A planning assumption of 100 GB per day was adopted to support vendor pricing comparison, storage estimation, and retention modelling. The architecture is built on Azure Log Analytics hosted in an Australian Azure region to meet data residency requirements, separating near-term detection from longer-term preservation with recent data in fast analytics storage and older data transitioning to lower-cost archival tiers (Microsoft, 2024c).

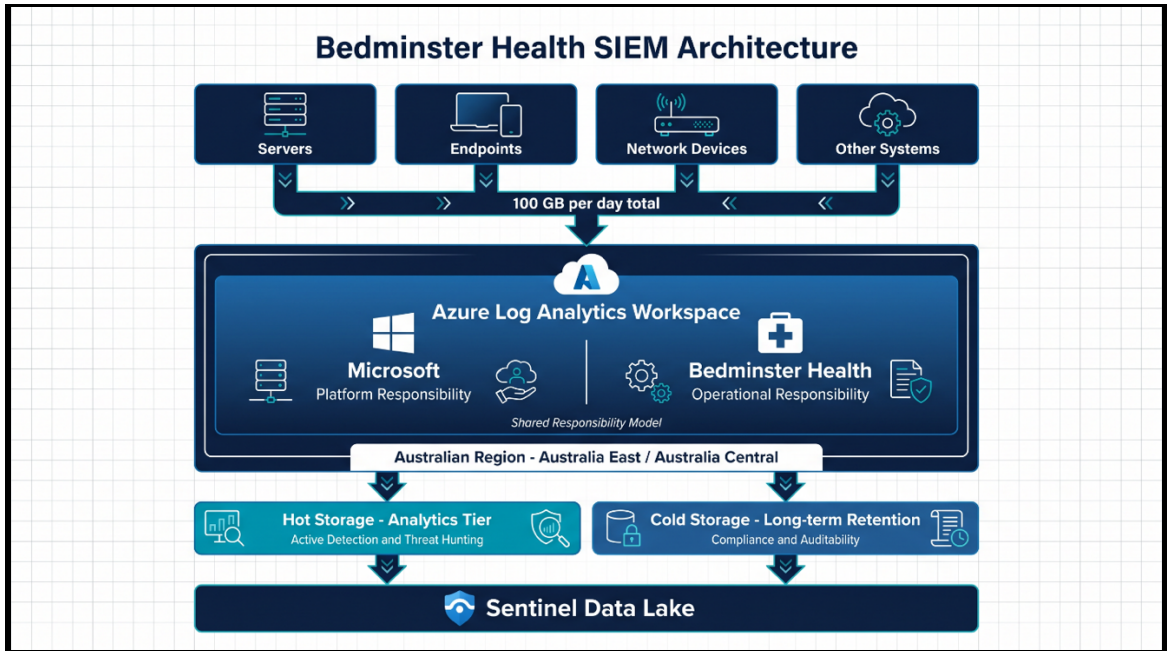


Figure 2: Bedminster Health SIEM Architecture.

7.2. Log Normalisation Strategy

Logs are generated in different formats across devices, systems, and vendors. The proposed solution relies on normalisation using data collection rules, parsers, and standardised schemas during or immediately after ingestion.

Normalization Flow

Step	What Happens?	Why It Matters?
Collect	Ingest logs via supported connectors, agents, and APIs.	Brings all relevant events into a single platform.
Parse & map	Apply rules/parsers to map vendor specific fields into a common schema (e.g., CommonSecurityLog, SecurityEvent).	Enables detections to use shared field names instead of device specific formats.
Enrich	Attach metadata such as site, asset type, and criticality.	Adds business context so alerts can be prioritised and compared across hospitals.
Route	Store events in appropriate tables based on type and schema.	Keeps queries, dashboards, and retention policies clean and efficient.
Detect & automate	Build KQL analytics and playbooks on the normalised fields.	Reduces rule duplication and simplifies ongoing maintenance.

Table 4: Log Normalisation Flow for Centralised SIEM Ingestion.

By applying this normalisation flow consistently, Bedminster Health can compare events across hospitals, engineer higher-quality KQL detections on shared fields, and keep the SIEM easier to manage over time.

7.3. Legacy Device and Log Onboarding Model

Because Bedminster Health includes heterogeneous and legacy technologies, a structured five-level onboarding model determines how each system contributes logs to Sentinel, providing a consistent decision framework rather than assuming a single integration method applies universally. Systems that cannot fit any level are documented as exclusions or later-phase candidates, prioritising reliable log collection over claims of immediate 100% coverage.

Five-Level Onboarding Model

Level	Method	Typical Use Case	When To Prefer It?
1	Direct agent (e.g., Azure Monitor Agent).	Modern servers and workstations that support the preferred SIEM agent.	Default option when the agent is supported and manageable.
2	Windows Event Forwarding (WEF).	Windows systems that cannot host the main agent but can forward events.	When agent install is constrained (legacy apps, support limits).
3	Syslog / CEF to collector VM.	Network devices, appliances, some Linux/Unix systems.	When native syslog/CEF support exists but agent is not suitable.
4	Third party agent (e.g., NXLog).	Legacy or niche systems where standard agents are not supported.	When software can be installed but native logging options are limited.
5	Vendor API / export.	Cloud apps, proprietary systems, and medical/clinical platforms with custom APIs.	When logs are only accessible via API or batch export.

Table 5: Five-Level Log Onboarding Model for Legacy and Heterogeneous Devices.

If a system cannot use any of these five levels, it is documented as an exclusion or a later-phase candidate rather than forced into a fragile integration. This model improves transparency and supports realistic SIEM success by prioritising reliable log collection over claims of immediate 100% coverage.

8. Detection and Response Engineering

8.1. KQL Detection Engineering for Bedminster Health

KQL is treated as the detection engineering layer of the Sentinel design, not just a search language. The goal is to produce targeted, high-value analytics rules that Bedminster Health's small IT team can realistically operate.

Detection Engineering Flow

Stage	What Is Done?	Why It Matters For Bedminster Health?
Define priority use cases	Identify key threats: credential abuse, impossible travel, privileged misuse, lateral movement, ransomware staging, logging failure.	Focuses effort on risks that align with Bedminster Health's clinical and operational impact.
Map data requirements	List required log sources and normalised fields for each use case.	Ensures rules are only built where the SIEM has the data to support them.
Design KQL patterns	Translate use cases into KQL patterns, thresholds, time windows, and table joins.	Produces specific, testable detections instead of noisy catch-all rules.
Tune and scope	Apply watchlists, service-account exclusions, and asset-criticality filters.	Reduces false positives and keeps alert volumes manageable for a small team.
Entity mapping	Map KQL outputs to users, hosts, IPs, and other entities.	Speeds up triage by showing who, what, and where in each incident.
Automate response	Attach automation rules and playbooks where appropriate.	Converts high-confidence detections into consistent, partially automated responses.

Table 6: KQL Detection Engineering Flow for Bedminster Health.

By following this structured KQL process, detections are tightly linked to priority risks, enriched with context (site, criticality, account type), and tuned to surface genuinely dangerous behaviour while minimising unnecessary triage.

8.2. Reducing MTTD, MTTR, MTTF, and MTBF

The Sentinel design reduces MTTD and MTTR through multi-source correlation, automated alert enrichment with user, host, geolocation, and threat-intelligence context, and orchestrated containment including account disabling and device isolation enabling a 30-person IT team to respond more quickly than is possible through manual log review.

Earlier detection of ransomware staging, anomalous privileged activity, and cross-site compromise also improves MTTF and MTBF indirectly by reducing the frequency and severity of security-induced service disruptions, a material benefit where clinical system availability directly affects patient care (HIMSS, 2023).

8.3. Reducing False Positives and Improving Workflow

The proposed approach reduces false positives through refined KQL logic, entity mapping, watchlists, and context-aware filters that suppress benign patterns while maintaining a full audit trail. In healthcare, alert fatigue can cause analysts to miss genuine threats, making detection quality as important as coverage. Better triage, escalation, and incident ownership also improve coordination across IT, system administrators, and leadership (ACSC, 2024).

9. Detection and Response Engineering

Connectors allow Sentinel to ingest, parse, and operationalise telemetry from identity systems, endpoints, servers, network devices, and cloud platforms. For Bedminster Health, the connector strategy is organised by source type, onboarding level, and implementation priority. Systems that cannot fit any onboarding level are recorded as exclusions rather than forced into an unreliable integration.

9.1. Prioritisation of Connectors

Connectors are prioritised in three tiers to ensure the highest-value sources are onboarded first, delivering immediate detection capability before more complex integrations are introduced.

Priority Tier	Source Focus	Rationale For Bedminster Health
Tier 1 - High	Identity, endpoint, firewall/VPN.	Highest value for detecting account compromise, lateral movement, and external intrusion early.
Tier 2 - Medium	Core servers, key applications.	Improves visibility into critical services and supports correlation with Tier 1 sources.
Tier 3 - Later phase	Complex legacy or niche clinical systems.	Onboarded once the platform, rules, and operating model are stable, to avoid early complexity.

Table 9: Connector Prioritisation Tiers for Sentinel Onboarding.

This gives Bedminster Health a scalable integration story: high-value identity, endpoint, and perimeter connectors are implemented first, with complex legacy or clinical integrations phased in once the platform and operating model are proven..

10. Data Management and Retention

10.1. Data Retention and Data Lake Strategy

Expectations, and cost control, using a tiered approach across analytics storage, data lake tiers, and long-term archive.

Tier	Storage Location	Typical Retention	Primary Purpose	Notes For Bedminster Health
Tier 1 - Analytics	Sentinel analytics workspace.	0-90 days.	Active detection, threat hunting, day to day incident investigation.	Uses the included analytics retention period so recent data is fast to query and fully integrated with Sentinel rules and workbooks.
Tier 2 - Data lake (online long term)	Sentinel data lake / lower cost log storage.	~1-2 years (key identity, server, network, audit logs).	Extended investigations, audits, trend analysis, and post incident reviews.	Keeps important datasets online at lower cost than analytics, accepting slightly slower queries in exchange for longer retention.
Tier 3 - Immutable archive	Long term archival / immutable storage.	Up to ~12 years or as required by policy.	Legal hold, regulatory evidence, rare deep forensic look backs.	Used for especially sensitive or evidentiary logs where policy or regulation requires strong preservation guarantees.

Table 10: Tiered Data Retention and Storage Strategy for Microsoft Sentinel.

Data retention is managed across three tiers: active security logs in analytics storage for 90 days, key identity, server, network, and audit datasets in the data lake for one to two years, and immutable archival copies for long-term audit and legal needs.

10.2. Log Integrity and Non-Repudiation

Log integrity is protected through encrypted transport, append-oriented storage in Azure Log Analytics, strict RBAC-based access controls, and export of high-value datasets to write-once, read-many Azure Storage. Sentinel's audit and health telemetry makes changes to analytics rules visible and reviewable, allowing Bedminster Health to monitor both raw log data and the integrity of the analytical content used to detect threats (Microsoft, 2024g).

11. Operation Resilience

11.1. Handling Spikes, Failures, and Crashes During Migration

A 100 GB per day migration cannot be treated as a single high-risk cutover. The approach uses phased onboarding by site and device class, DCR-based filtering from day one, and KQL monitoring of ingestion usage to control volume spikes. Azure Monitor's buffering and retry mechanisms absorb transient disruptions, while rollback runbooks and continuous export ensure data continuity if instability occurs (Microsoft, 2024h).

11.2. Break-Glass Access and Emergency Cloud Operations

Bedminster Health must maintain protected break-glass administrative accounts excluded from ordinary conditional-access policies, secured separately, and monitored so any use triggers a high-priority alert. Emergency runbooks should define authority for emergency actions, rollback procedures, and methods for disabling compromised automations, demonstrating to auditors that failure scenarios have been planned for (NIST, 2020).

12. Compliance and Governance

12.1. Compliance, Accountability, and Shared Responsibility

The proposed Sentinel design must operate within Bedminster Health's legal and governance context. The table below summarises the primary compliance frameworks relevant to an Australian healthcare organisation and the logging and monitoring expectations that inform this business case.

Lens / Framework	Why It Matters For Bedminster	What It Mainly Expects From Logging / SIEM
Privacy Act 1988 & (APPs)	Core Australian law for personal and health information.	Secure log storage, access controls, breach detection, and compliant retention.
ACSC Essential Eight & ACSC cyber security guidance	Baseline cyber-resilience expectations for Australian critical sectors.	Centralised logging, privileged-activity monitoring, and structured incident response.
Health Records Legislation	State obligations for EHR and clinical system access.	Detailed access logs, monitoring for misuse, and long-term audit trail preservation.
Australian digital health	Guidance on cloud adoption for health information processing.	Australian data residency, encryption, RBAC, and cloud misconfiguration monitoring.
ISO 27001	Formal security governance framework for external audit.	Centralised logging for in-scope systems and evidence of continuous improvement.

Table 11: Compliance and Regulatory Frameworks for SIEM Governance at Bedminster Health.

In line with the cloud shared responsibility model:

- Microsoft is responsible for securing the Sentinel platform and offering encryption, region choice, access control and auditing.
- Bedminster Health is responsible for selecting an Australian region, setting and enforcing retention, deciding which systems must be logged (especially EHR and other clinical systems), and controlling who can see SIEM data.
- Sentinel provides the technical capability to meet these logging and monitoring expectations, but compliance only holds if Bedminster operates the surrounding elements: policies, incident handling, privacy processes, and regular reviews of SIEM coverage and configuration.

12.2. SIEM Transition Risk Register

Implementing Sentinel is itself a material change carrying project, operational, and cultural risks that must be actively managed. The table below summarises key SIEM-specific risks for Bedminster Health, with likelihood, impact, mitigations, and residual risk.

Risk ID	Risk description	Likelihood	Impact	Mitigation / controls	Residual risk
R1	Ingestion volume and cost blow out due to noisy logs.	Medium.	High.	Phased onboarding, DCR filtering from day one, weekly GB monitoring.	Low-Medium.
R2	Alert fatigue from poorly tuned rules.	Medium.	High.	Start with a small set of high-value detections; review rule performance weekly.	Low-Medium.
R3	Coverage gaps for legacy and clinical systems.	Medium.	High.	Apply L1–L5 framework, maintain a log-source inventory, document exclusions.	Medium.
R4	Insufficient staff skills; Sentinel used as a log bucket only.	Medium.	High.	Budget for Sentinel/KQL/SOAR training and assign clear SIEM ownership.	Medium.
R5	Cloud misconfiguration reduces visibility.	Low-Medium.	High.	Use RBAC, resource locks, continuous export, and Sentinel health monitoring.	Low-Medium.

R6	Cultural resistance from operational and clinical teams.	Medium.	Medium – High.	Early stakeholder engagement and leadership sponsorship.	Medium.
R7	Over-reliance on Sentinel; underinvestment in foundational controls.	Low-Medium.	High.	Link SIEM metrics to ACSC Essential Eight; treat SIEM as one control among many.	Low-Medium.
R8	Out-of-the-box vendor detection rules may produce coverage gaps without local tuning.	Medium.	Medium.	Treat vendor content as a starting point; assign ownership for periodic detection review and tuning.	Low-Medium.

Table 12: SIEM Transition Risk Register for Bedminster Health.

13. Organisational Benefits

The proposed SIEM solution delivers benefits across three areas: visibility and governance, response workflow, and economic risk reduction.

13.1. Improved Visibility and Governance

The solution gives Bedminster Health centralised visibility across all five hospital sites, improving the ability to identify suspicious behaviour before it escalates. Stronger retention, audit trails, region-aware storage, and immutable exports provide evidence for investigations, privacy assessments, and executive oversight.

13.2. Faster, More Coordinated Incident Response

Real-time correlation and automated playbooks streamline root-cause analysis by assembling related events and applying predefined workflows. Analysts receive a consolidated incident view routed to the appropriate on-call team, with automated responses available for high-risk patterns. This can reduce detection and response times from hours to minutes across all five sites (HIMSS, 2023).

13.3. Economic Justification and Real World Breach Costs

The proposed stack costs approximately A\$244,000 per year. By contrast, Australian Clinical Labs was ordered to pay A\$5.8 million in civil penalties following a 2022 data breach (Federal Court of Australia, 2025), and IBM Security places the global average healthcare breach cost at US\$9.77 million (IBM Security, 2024). Avoiding a single serious incident over a decade would more than justify the Sentinel investment.

14. Implementation Roadmap

A staged implementation is recommended for controlled adoption. Phase 1 establishes the Sentinel workspace, governance, break-glass access, and RBAC. Phase 2 onboards priority sources, identity, endpoint, and perimeter with DCRs, normalisation logic, and usage monitoring configured from the outset. Phase 3 builds and tunes KQL detections and playbooks around credential abuse, privileged misuse, and ransomware staging, with a later phase expanding to legacy and complex systems.

15. Future Work and Extension Opportunities

Bedminster Health has future monitoring requirements in clinical IoT, biomedical systems, and hospital critical infrastructure, excluded from Phase 1 due to specialised safety and protocol considerations. A future extension should examine bedside monitors, imaging equipment, smart infusion devices, and building-management systems such as HVAC and backup power, systems that may require passive monitoring or dedicated IoT/OT tools forwarding alerts into Sentinel.

16. Reflection on Team and Individual Contribution

This project applied more than three evaluation metrics across technical analysis, cost modelling, governance design, and business justification, consistent with the HD requirement for detailed, multi-dimensional reflection on team progress and individual contributions (Gartner, 2024; ACSC, 2024; Microsoft, 2024a).

The technical work spanned SIEM market research, ingestion modelling, architecture design, and linking decisions to measurable outcomes including reduced MTTR, lower alert fatigue, and stronger compliance readiness. SIEM selection in healthcare is an exercise in balancing risk, cost, operational maturity, and regulatory expectations, the project reinforced that governance, staff enablement, and sustained tuning are as critical as platform selection.

17. Conclusion

Bedminster Health's current monitoring position leaves the organisation exposed to delayed threat detection, fragmented visibility, and elevated risk. This business case demonstrates that Microsoft Sentinel is the most suitable SIEM among the shortlisted candidates, offering strong value for money, integrated automation, scalable cloud-native operation, and practical fit for a large healthcare organisation with limited specialist staffing. The recommendation is supported by a clear onboarding model, a realistic cost and retention strategy, an Australian-region data residency approach, and explicit treatment of migration risks and cloud misconfiguration providing a logical, practical pathway from reactive visibility to a proactive and resilient monitoring capability.

18. Approval

This project report for the SIEM project dated 20/05/26 is approved.

Name	Role	Signature	Date
Aakritansh Modgil	Student		20/05/2026
Humayra Ashrafi	Student		20/05/2026
Jithu Johan Jose	Student		20/05/2026
Junaaid Abrar Razeen	Student		20/05/2026
Promise Rijal	Student		20/05/2026
Ruichao Li	Student	Ruichao Li.	20/05/2026
David Menzies	Mentor		20/05/2026

Table 13: Approval Table

References

- Australian Clinical Labs. (2025). Federal Court orders A\$5.8 million penalty following Medlab Pathology data breach [Media release]. Australian Clinical Labs.
- Australian Digital Health Agency (ADHA). (2023). My Health Record: Security and access policy. ADHA. <https://www.digitalhealth.gov.au>
- Australian Cyber Security Centre (ACSC). (2024). Essential Eight maturity model. Australian Signals Directorate. <https://www.cyber.gov.au/resources-business-and-government/essential-cyber-security/essential-eight>
- Federal Court of Australia. (2025). Australian Information Commissioner v Australian Clinical Labs Pty Ltd [2025] FCA [docket]. Federal Court of Australia.
- Gartner. (2024). Magic quadrant for security information and event management. Gartner Research.
- HIMSS. (2023). 2023 HIMSS cybersecurity survey. Healthcare Information and Management Systems Society. <https://www.himss.org/resources/himss-cybersecurity-survey>
- IBM Security. (2024). Cost of a data breach report 2024. IBM Corporation. <https://www.ibm.com/reports/data-breach>
- Microsoft. (2024a). Microsoft Sentinel overview. Microsoft Learn. <https://learn.microsoft.com/en-us/azure/sentinel/overview>
- Microsoft. (2024b). Microsoft Sentinel pricing. Microsoft Azure. <https://azure.microsoft.com/en-au/pricing/details/microsoft-sentinel/>
- Microsoft. (2024c). Data retention and archival in Microsoft Sentinel. Microsoft Learn. <https://learn.microsoft.com/en-us/azure/sentinel/data-retention-archive>
- Microsoft. (2024d). Data collection rules in Azure Monitor. Microsoft Learn. <https://learn.microsoft.com/en-us/azure/azure-monitor/essentials/data-collection-rule-overview>
- Microsoft. (2024e). KQL quick reference. Microsoft Learn. <https://learn.microsoft.com/en-us/azure/data-explorer/kql-quick-reference>
- Microsoft. (2024f). Microsoft Sentinel data connectors. Microsoft Learn. <https://learn.microsoft.com/en-us/azure/sentinel/connect-data-sources>

- Microsoft. (2024g). Auditing and health monitoring in Microsoft Sentinel. Microsoft Learn. <https://learn.microsoft.com/en-us/azure/sentinel/audit-sentinel-data>
- Microsoft. (2024h). Azure Monitor reliability and availability. Microsoft Learn. <https://learn.microsoft.com/en-us/azure/azure-monitor/reliability/reliability-azure-monitor>
- Microsoft. (2024i). Shared responsibility in the cloud. Microsoft Learn. <https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility>
- National Institute of Standards and Technology (NIST). (2020). Security and privacy controls for information systems and organisations (SP 800-53 Rev. 5). NIST. <https://doi.org/10.6028/NIST.SP.800-53r5>
- Office of the Australian Information Commissioner (OAIC). (2023). Privacy Act 1988: Guidance for health service providers. OAIC. <https://www.oaic.gov.au/privacy/health-information>
- SANS Institute. (2023). SIEM implementation guide: Detection engineering best practices. SANS Reading Room. <https://www.sans.org/reading-room/>